
Tutorial 8

Detecting and Preventing Intrusions

Computer Security

BCS2420

Part A

1. Which statement correctly describes the difference between an Intrusion Detection System (IDS) and an Intrusion Prevention System (IPS)?
 - ☐ An IDS can block malicious packets in real time, while an IPS can only alert.
 - ☐ An IDS passively monitors and alerts on suspicious activity, while an IPS can also actively block or modify traffic.
 - ☐ Both IDS and IPS require real-time packet dropping.
 - ☐ An IPS always uses anomaly-based detection, whereas an IDS is purely signature-based.
2. An anomaly-based IDS has a 1% false positive rate and detects 90% of attacks. If the actual rate of attacks is extremely low, which outcome is most likely in practice?
 - ☐ The IDS rarely triggers alarms at all.
 - ☐ Most alarms raised will be false alarms.
 - ☐ Nearly all alarms will be true positives.
 - ☐ The base rate does not affect the proportion of false alarms.
3. What is a fundamental limitation of signature-based intrusion detection?
 - ☐ It cannot process more than 1 Gbps of traffic.
 - ☐ It can only detect known attack patterns and must be frequently updated.
 - ☐ It has zero false positives but high false negatives.
 - ☐ It exclusively relies on user-provided rule sets to

define normal behavior.

4. A specification-based approach to intrusion detection:
 - ☐ Learns normal behavior from a training dataset automatically.
 - ☐ Raises alarms when events *match* known malicious signatures.
 - ☐ Checks events against explicitly defined rules for allowed behavior, flagging anything outside that specification.
 - ☐ Relies primarily on packet header inspection rather than content.
5. Which factor contributes **most** to high false positives in anomaly-based IDS?
 - ☐ Deficient hardware resources
 - ☐ Intruder-free training data
 - ☐ Profiles that may not accurately capture the full range of normal behavior
 - ☐ Excessive reliance on known attack patterns
6. A host-based intrusion detection system (HIDS) typically monitors:
 - ☐ Network traffic at the perimeter router only
 - ☐ OS logs, file integrity, and processes on a single host
 - ☐ ARP broadcasts on a local network
 - ☐ Physical security cameras inside a data center
7. In the context of IDS terminology, a **false negative** is:
 - ☐ When the system incorrectly flags benign activity as malicious
 - ☐ When the system fails to detect a real intrusion
 - ☐ When the alarm precision is below 50%
 - ☐ When an anomaly-based system incorrectly classifies new attacks as normal
8. Network-based IDS often uses packet sniffer components. Why might sniffing be harder on a switched LAN compared to a hub-based LAN?
 - ☐ Switches do not forward all traffic to every port, making promiscuous capture of packets more difficult.
 - ☐ Switches automatically decrypt all packets at layer 2.
 - ☐ Hub-based LANs are usually physically protected and cannot be tapped.

- ☐ Switches seldom store ARP entries in memory.
- 9. How does DNS cache poisoning enable an attacker to redirect user traffic?
 - ☐ By substituting a malicious local hosts file on the client
 - ☐ By manipulating the user's private IP address to MAC address mapping
 - ☐ By inserting false name-to-IP mappings in a DNS resolver's cache
 - ☐ By encrypting DNS queries end-to-end
- 10. Which scenario **best** represents ARP spoofing on a LAN?
 - ☐ An attacker forges IP source addresses in TCP packets destined for a remote host.
 - ☐ An attacker sends unsolicited ARP replies claiming the gateway's IP belongs to the attacker's MAC.
 - ☐ An attacker manipulates DNS queries to point to a malicious server.
 - ☐ An attacker runs Nmap to scan open TCP ports.

Part B

1. **Detecting DDoS**

- **Question:** In large networks, how can an IDS differentiate between normal traffic spikes (e.g., flash crowds) and an **actual DDoS**? Describe **two** advanced techniques or heuristics an IDS might employ.

2. **Base Rate Fallacy**

- **Question:** Suppose an anomaly-based IDS has a 1% false positive rate and 95% detection rate, but actual intrusions happen only once per 10,000 events. Calculate conceptually how many false alarms vs. real alarms to expect in 100,000 events. Explain why the result might be problematic for analysts.

3. **Signature vs. Anomaly**

- **Question:** Compare **two** real-world scenarios—one ideally suited for **signature-based** detection and another for **anomaly-based** detection. Justify why each approach fits the scenario.

4. **Specification-Based IDS Complexity**

- **Question:** Why can specification-based IDS be labor-intensive? Give **one** example of a complex system or

protocol where writing a correct specification is challenging.

5. **Vulnerability Scanners**

- **Question:** Outline how a vulnerability scanner like **Nessus** or **OpenVAS** might systematically check for known security holes. Mention **two** limitations or risks of relying on such automated scans.

6. **Mitigating ARP Spoofing**

- **Question:** In a large corporate LAN, how might network admins reduce ARP spoofing attacks? Discuss **two** solutions and potential drawbacks.

7. **DNS Cache Poisoning**

- **Question:** Provide **one** attacker method for DNS cache poisoning (without DNSSEC) and **two** countermeasures that resolvers or OSes can implement.

8. **SYN Flooding**

- **Question:** Summarize how a classic SYN flood can cause a DoS and explain how SYN cookies specifically mitigate the resource exhaustion problem.

9. **Smurf/Amplification**

- **Question:** The Smurf attack is an older but instructive example of **ICMP-based** amplification. If an attacker can produce an amplified factor of 100, how does that occur, and how do modern networks mitigate it?

10. **IDS Evasion**

- **Question:** Attackers can craft packets or flows to evade detection by certain IDS. Give **two** examples of evasion techniques and how modern IDS might counter them.

Part C

1. **False Positives and Negatives**

- **Question:** You have an IDS with a **2%** false positive rate (FPR) and **90%** detection rate (true positive rate). Each day there are **200** real intrusions and **10,000** non-intrusive events.
 1. How many **false negatives** occur daily?
 2. How many **false positives**?

2. **Anomaly Alert Volume**

- **Question:** An anomaly-based IDS sees **1 million** events/day, among which only **200** are actual attacks. Suppose it catches **90%** of these attacks but triggers alarms on **2%** of benign events.
 1. How many total alarms?
 2. How many of these alarms correspond to real attacks?

3. **Base Rate**

- **Question:** If an IDS is **99%** accurate (meaning for any event, it has a 1% chance to misclassify), but actual intrusions are 0.1% of all events, what is the probability an alarm is a *real intrusion*? (Hint: apply Bayes' Theorem or conceptual reasoning.)

4. **DoS Bandwidth**

- **Question:** An attacker floods **100,000** pps at **512** bytes each.
 1. What is the approximate bandwidth of this DoS in Mbps?
 2. If the target's uplink is **100 Mbps**, can this alone saturate the link (assuming no overhead)?
-